Documentación de seguridad y resiliencia: CRM Leads – Entrega Final

Flujo: Tally (webhook) → n8n → Airtable → OpenAI `gpt-5-mini` → Gmail, con aprobación humana para leads VIP.

---

1. Minimización de datos

1.1 Qué datos entran y qué se envía a la IA

Dato	Se guarda en Airtable	Se envía a la IA	Justificación
Nombre	Sí	**No**	Solo se usa para personalizar el asunto del mail
Email	Sí	**No**	Solo se usa como destinatario
Mensaje / consulta	Sí	**Sí** (único dato enviado)	Es lo único necesario para clasificar y redactar

El prompt de la IA usa únicamente la variable `{{ $json.fields.Mensaje }}`. El modelo nunca recibe el nombre ni el correo del lead, por lo que no puede filtrarlos en su salida ni quedan en los registros del proveedor de IA junto con el mensaje.

1.2 Otras medidas

- **Registro de errores sin datos personales:** cuando faltan datos, la tabla `Errores` guarda solo qué campo faltó (`Email: presente | Mensaje: FALTA`), no el contenido del formulario.
- **Sin lead ante datos incompletos:** si falta el email o el mensaje, el flujo corta antes de crear el registro en `Leads`, así no se almacenan datos parciales.
- **Credenciales fuera del flujo:** Airtable y Gmail usan OAuth2 y OpenAI usa una credencial gestionada, todas guardadas en el gestor de credenciales de n8n. El JSON exportado contiene solo referencias, no claves ni tokens.
- **Sin datos hardcodeados en el prompt ni en los mensajes:** nombre, mensaje y respuestas se toman de variables del sistema.
- **Límite de salida de la IA:** `maxTokens: 2000` y formato de salida fijado por un *Structured Output Parser*.

- **Acceso a la base:** el dashboard público y el enlace de lectura exponen solo las vistas de KPIs; no se comparte la tabla `Leads` con datos personales. *(Confirmar que la Shared View oculte Nombre, Email y Mensaje.)*

---

2. Rutas de error (resiliencia)

2.1 Rutas implementadas

#	Falla que cubre	Dónde se detecta	Qué hace el sistema	Resultado
E1	Formulario con email o mensaje vacío	Nodo `Validar datos completos` (If, salida *false*)	Va a `Registrar datos incompletos` y crea una fila en `Errores`	No se crea el lead, no se gasta IA, queda rastro
E2	Falla de la API de IA (timeout, límite de tasa, error del proveedor)	Nodo `Clasificar lead con IA`, configurado como *On Error: Continue (using error output)*	Sale por la salida de error hacia `Registrar error de IA`; crea una fila en `Errores` **vinculada al lead**	El flujo no se rompe; el lead queda en estado `Pendiente` para revisión manual

Ambas rutas escriben en la tabla `Errores`, que alimenta la **tasa de errores** del dashboard de control.

2.2 Protección contra bucles infinitos

El flujo se dispara únicamente por un **webhook de Tally** (una ejecución por envío de formulario). Ninguna de las escrituras del flujo (Airtable, Gmail) vuelve a dispararlo, y no hay un trigger sobre cambios en la base de datos, por lo que no existe un camino que lo reinicie a sí mismo. El estado `Pendiente` se asigna una sola vez, al crear el lead.

2.3 Tipos de datos en los filtros

Todos los filtros comparan **texto con texto**, con validación de tipos estricta: `notEmpty` sobre `email` y `mensaje` en el If, y `equals` de `Clasificación` contra `"VIP"` / `"Normal"` en el Switch.

2.4 Limitaciones conocidas (estado actual)

Riesgo	Situación actual	Mejora propuesta

Falla de Gmail o Airtable	Solo el nodo de IA y la validación tienen ruta de error. Un fallo en otros nodos detiene la ejecución y queda solo en el historial de ejecuciones de n8n	Activar *Continue on Fail* y registrar en `Errores`, o crear un *Error Workflow* global
Clasificación fuera de "VIP"/"Normal"	El Switch no tiene salida de respaldo (*fallback*); un valor inesperado terminaría la ejecución sin registro	Agregar salida *fallback* hacia `Errores`
Validación de formato de email	El If comprueba que el campo no esté vacío, no que sea un email válido	Agregar validación de formato
Hilos de Gmail (Thread ID)	Cada consulta genera un mail nuevo; no hay conversación previa que continuar	Guardar el `threadId` en `Leads` si se quiere seguimiento

---

3. Human-in-the-loop (HITL)

3.1 Punto de aprobación

Aspecto	Detalle
Dónde	Rama VIP, nodo `Pedir aprobación humana` (Gmail, operación *Send and Wait*)
Qué se revisa	Nombre, email, consulta original y la **respuesta propuesta por la IA**
Cómo se aprueba	El responsable recibe un mail con botón **Aprobar**; la ejecución queda pausada hasta que responde
Qué se bloquea	`Enviar respuesta VIP` (contacto con el cliente) y `Marcar como Aprobado`
Por qué en VIP	Son los clientes de mayor valor; un mensaje equivocado tendría el mayor costo comercial

Esto evita el "efecto metralleta": el sistema no contacta a un lead VIP sin decisión humana.

3.2 Rama Normal

Las respuestas a leads Normal se envían automáticamente. Es una decisión consciente: el mensaje es una confirmación genérica de recepción (dos o tres líneas) y no compromete al negocio. El texto lo redacta la IA con formato fijo por el parser.

3.3 Limitaciones y mejoras del HITL

Situación	Estado actual	Mejora propuesta
El revisor no responde	El mail de aprobación no tiene límite de espera configurado; la ejecución queda en espera y el lead en `Procesado por IA`	Configurar tiempo límite y notificar/registrar en `Errores` al vencer
El revisor rechaza	El mail ofrece solo **Aprobar**; rechazar equivale a no responder	Usar aprobación con opciones *Aprobar / Rechazar* y una rama de rechazo que actualice el estado
Destinatario de la aprobación	Definido dentro del nodo	Pasarlo a una variable de n8n o a una tabla de configuración

---

4. Riesgos de seguridad adicionales y mitigaciones

Riesgo	Explicación	Mitigación
Webhook sin autenticación	La URL de producción es la única barrera (ruta con identificador aleatorio). Quien la conozca puede enviar datos falsos, que terminarían enviando mails desde la cuenta de Gmail conectada	Agregar autenticación por cabecera o firma de Tally; no publicar la URL; regenerar la ruta del webhook antes de subir el JSON al repositorio
Inyección de prompt	El texto del lead entra al prompt. Alguien podría intentar manipular la respuesta de la IA	Salida limitada por el parser (clasificación + textos cortos); los borradores VIP pasan por revisión humana; los Normal son confirmaciones genéricas
Uso como relé de correo	El destinatario sale del formulario, así que se podría usar el flujo para enviar mails a terceros	Validar formato de email, autenticar el webhook y limitar la frecuencia por origen
Datos personales en el repositorio	Las capturas y el JSON son públicos	Revisar capturas (tapar emails y nombres reales) y usar datos ficticios en los ejemplos
Secretos en el JSON	El export contiene IDs de credenciales, de base y de tablas de Airtable (no claves)	Confirmar que no haya tokens; no incluir la URL de producción del webhook

---

5. Checklist de seguridad (previo a la entrega)

Pregunta	Respuesta
¿Hay filtro contra bucles infinitos?	Sí: trigger por webhook, sin disparadores sobre la base; ver 2.2
¿Se comparan tipos de datos correctos?	Sí: texto contra texto con validación estricta; ver 2.3
¿El prompt de IA es dinámico?	Sí: usa `{{ $json.fields.Mensaje }}`
¿Hay ruta de error si falla la IA?	Sí: E2, con registro vinculado al lead
¿Hay validación humana antes de contactar al cliente final (VIP)?	Sí: `Pedir aprobación humana`
¿Hay datos sensibles hardcodeados?	Ver 3.3: el mail del aprobador debe pasar a variable antes de entregar